

PILOTAGE AUDIT

# Piloter les tests d'intrusion, de la programmation à la restitution

Planification multi-échelles · Kanban configurable · Tableaux de bord des temps réels · Import en masse des TI

Présentation fonctionnelle à destination de l'équipe

Toutes les captures de ce document proviennent de l'application, alimentée avec un jeu de **données fictives**.

## EN BREF

# À quoi sert l'application

Pilotage Audit centralise la **programmation et le suivi des tests d'intrusion et audits techniques** : quels TI sont prévus, quand, par qui, avec quel prestataire, où en est chacun et combien de temps ils ont réellement pris. L'outil remplace les tableurs de planification et les échanges de mails de suivi, sans se substituer aux outils de gestion des vulnérabilités.

## Périmètre volontairement limité

L'application **ne stocke ni les résultats d'audit ni les vulnérabilités**. Elle traite des informations de pilotage : planning, charge, contacts, pré-requis, et les documents que les équipes y attachent. Ce choix limite la sensibilité des données et simplifie les habilitations.

## Ce que l'équipe y gagne

- **Une seule vue du portefeuille** : plus de tableur par pilote, ni de version qui diverge.
- **Un planning à l'échelle du besoin** : la semaine d'un auditeur comme le cycle d'audit de trois ans.
- **Des chiffres sur les durées réelles** : écart au planning, respect des délais, charge par prestataire.
- **Une reprise de l'existant en quelques minutes** grâce à l'import en masse des TI.
- **Un outil qui s'adapte sans développement** : colonnes du kanban, catégories, étiquettes et champs additionnels se configurent en ligne.

## Les rôles

|                               |                                                                                             |
|-------------------------------|---------------------------------------------------------------------------------------------|
| <b>Administrateur</b>         | Configure l'outil (kanban, catégories, étiquettes, champs, comptes) et accède à tout.       |
| <b>Pilote d'audit</b>         | Crée et suit les audits, les phases, les pré-requis et les documents ; réalise les imports. |
| <b>Responsable de service</b> | Consulte les audits de son périmètre, coche les pré-requis, suit l'avancement.              |

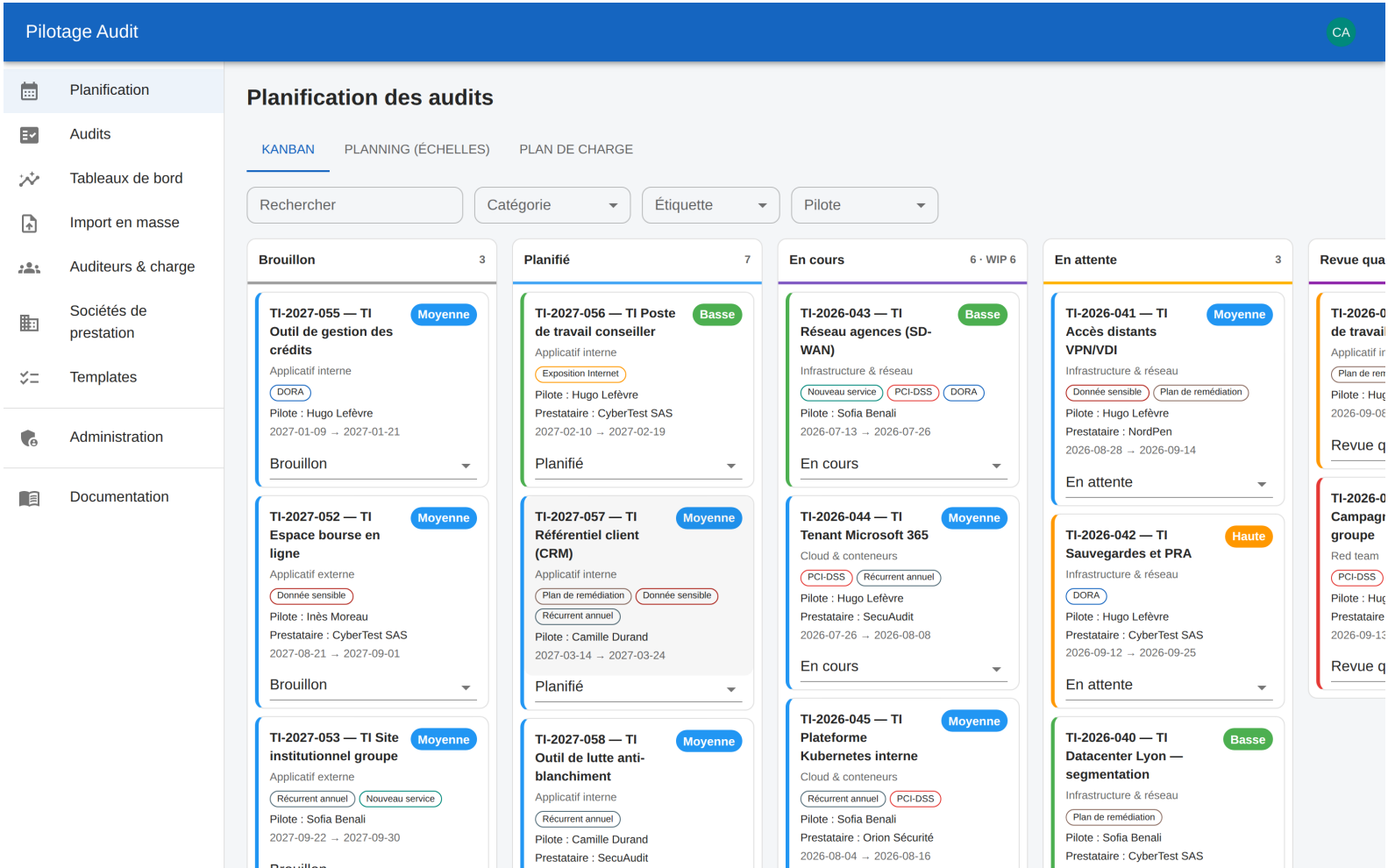
## En pratique

|                      |                                                                                                  |
|----------------------|--------------------------------------------------------------------------------------------------|
| <b>Accès</b>         | Navigateur, sur le réseau interne. Authentification par compte nominatif (extension SSO prévue). |
| <b>Installation</b>  | Trois conteneurs (base de données, API, interface). Mise à jour par redémarrage.                 |
| <b>Volumétrie</b>    | Validée jusqu'à 5 000 audits et 25 000 phases : écrans du quotidien sous 250 ms.                 |
| <b>Documentation</b> | Intégrée à l'application, et détaillée dans le dépôt (dossier docs/).                            |

# Le kanban : où en est chaque TI

La page d'accueil montre l'état réel du portefeuille. Chaque carte est un TI : référence, catégorie, étiquettes, pilote, prestataire et fenêtre prévue. On déplace une carte par glisser-déposer (ou via le sélecteur au bas de la carte) et le statut suit automatiquement.

- Les colonnes sont définies par l'administration : ici une colonne « Revue qualité » a été ajoutée au cycle standard.
- La colonne « En cours » porte une limite d'en-cours (WIP 6) : le dépassement est signalé.
- Filtres immédiats : recherche libre, catégorie, étiquette, pilote.

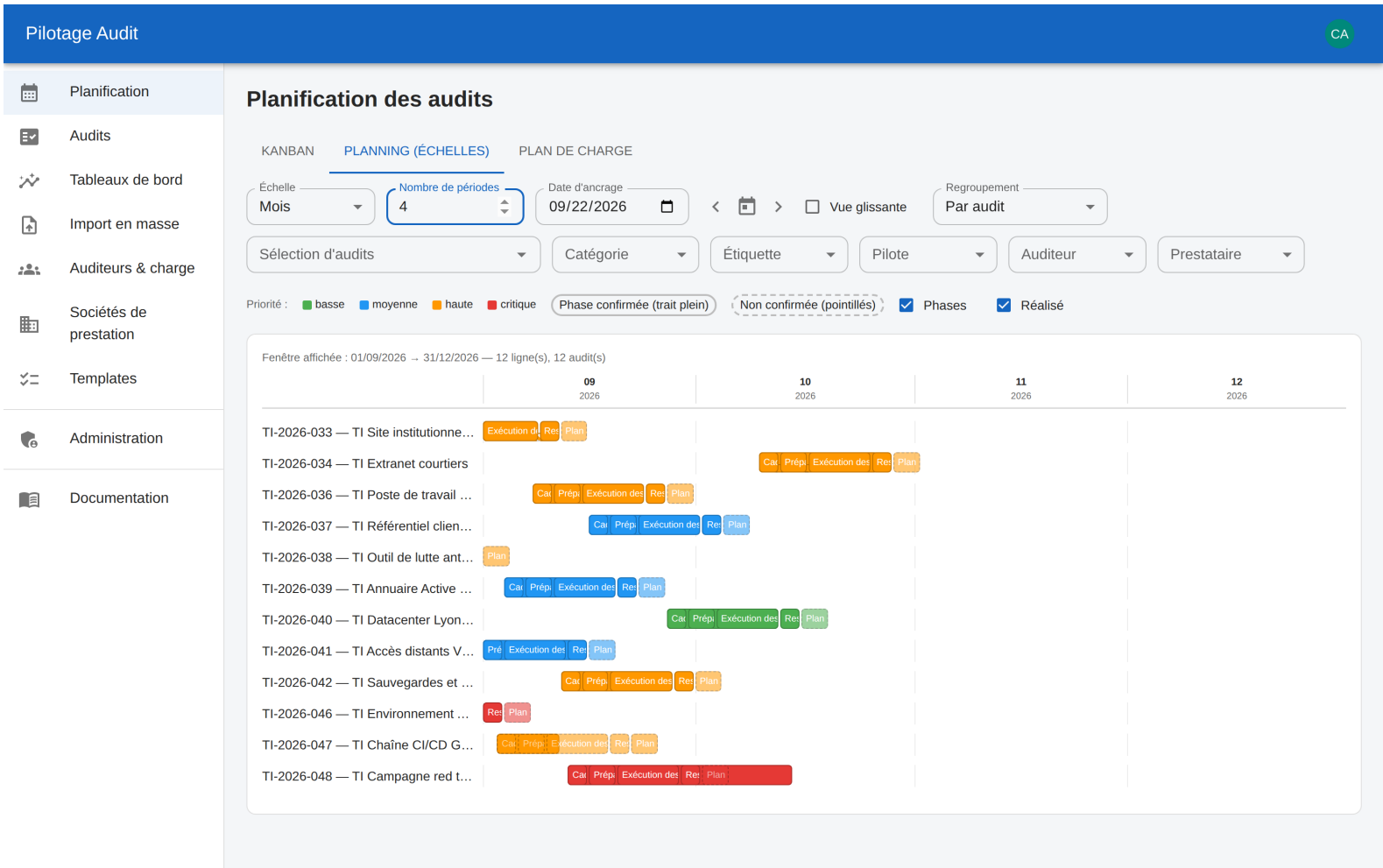


Kanban — 58 TI fictifs répartis sur 2025-2027.

# Le planning, à l'échelle que l'on choisit

Le même portefeuille se lit au jour, à la semaine, au mois, au trimestre, à l'année ou sur un cycle pluriannuel. La fenêtre peut être alignée sur la période ou **glissante** à partir d'une date. Barre pleine = planifié, barre hachurée = réalisé, pointillés = phase non confirmée.

- Ici : échelle « Mois », 4 mois affichés, une ligne par audit avec le détail des phases.
- Chaque phase porte son auditeur : le planning sert aussi à arbitrer les affectations.
- Un clic sur une barre ouvre la fiche de l'audit.

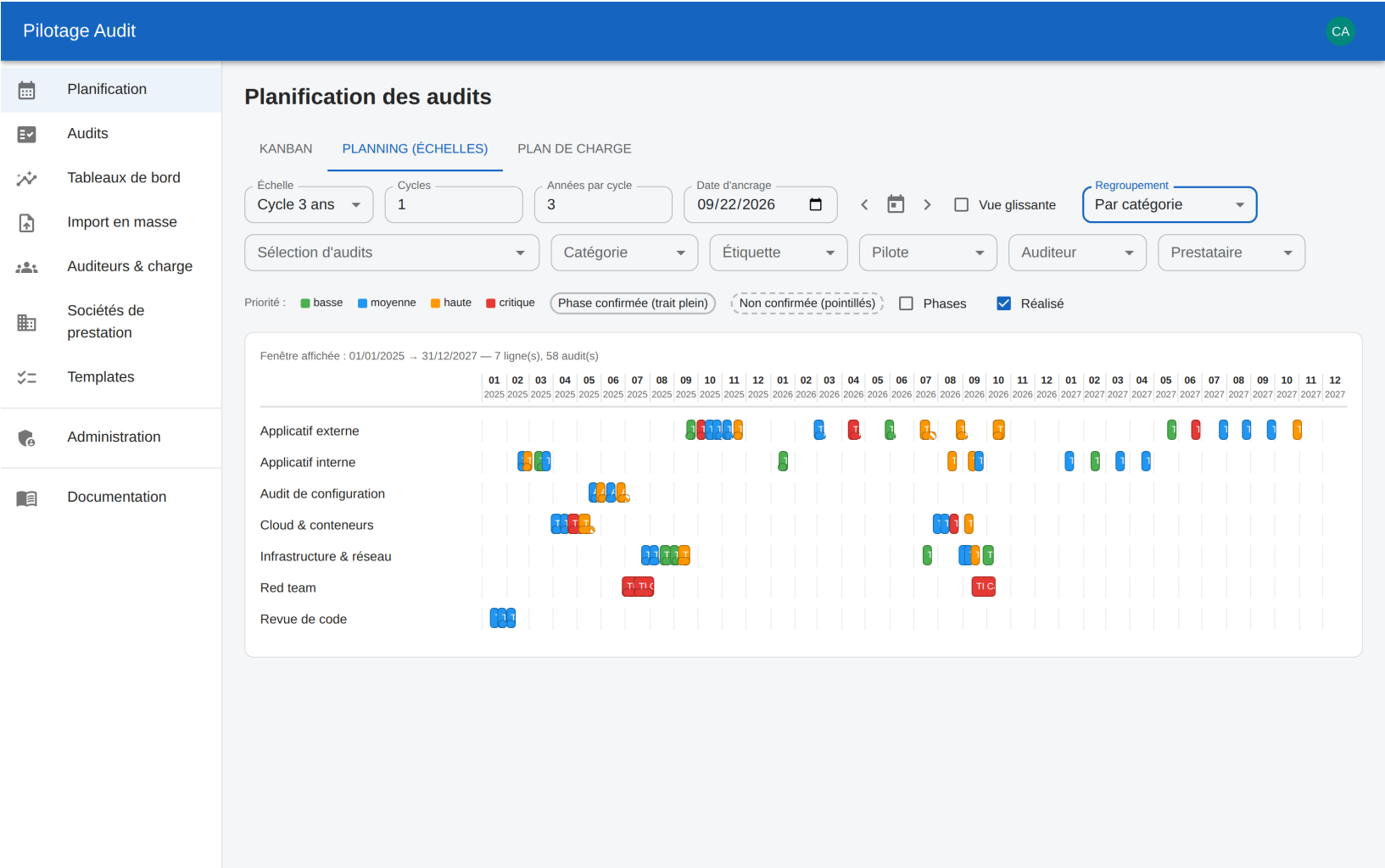


Planning — vue mensuelle, regroupement par audit.

# La vision de cycle : trois ans d'un coup d'œil

À l'échelle « Cycle 3 ans », le planning montre la couverture d'audit sur l'ensemble du cycle. Le regroupement par catégorie répond directement à la question de la couverture : quelles familles de systèmes ont été testées, lesquelles restent à programmer.

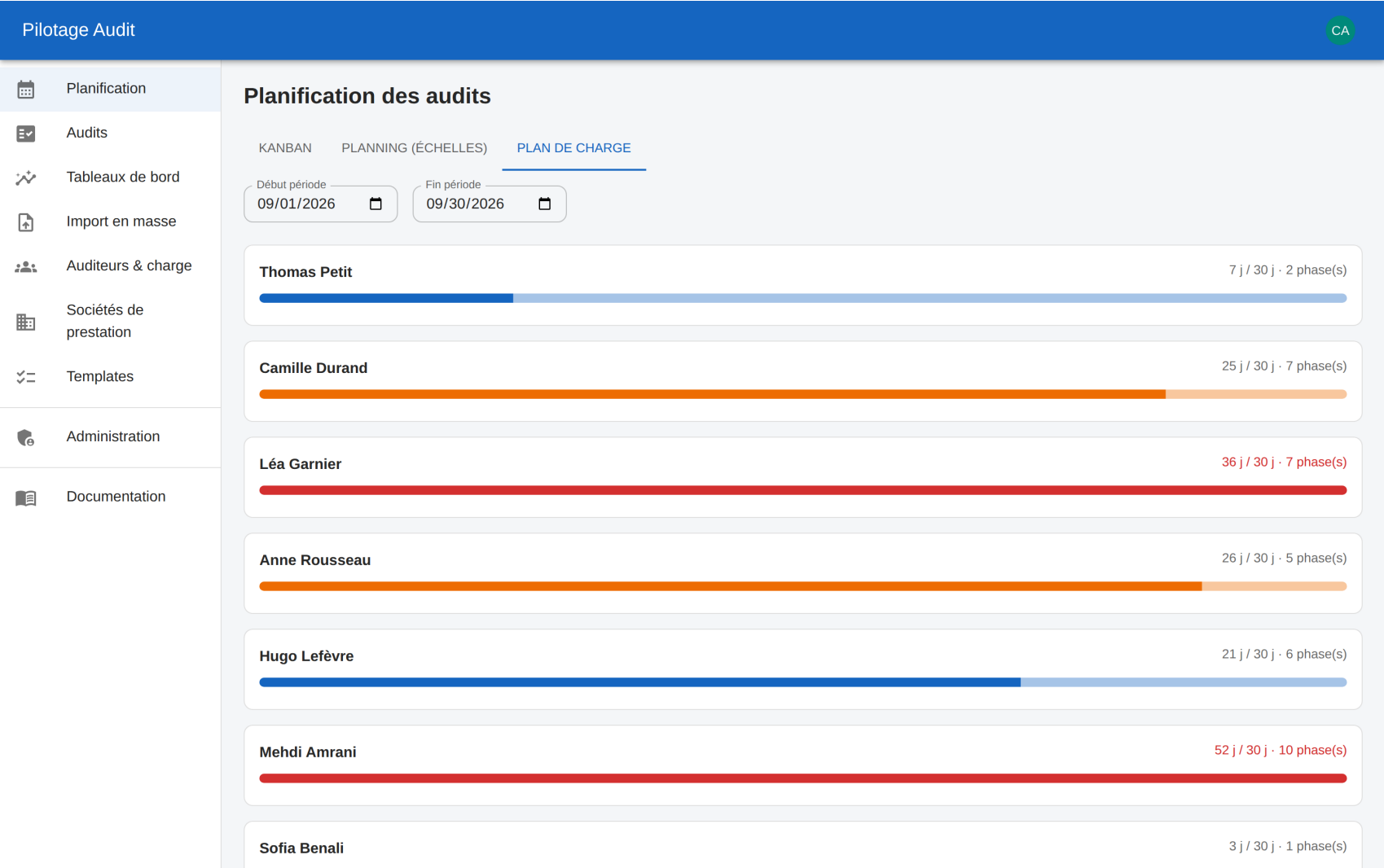
- Regroupement au choix : par audit, catégorie, pilote, prestataire ou auditeur.
- La sélection d'audits permet d'isoler un programme précis (ex. la trajectoire DORA).
- Le nombre d'années par cycle est paramétrable.



# Qui est disponible, et quand

Le plan de charge additionne, sur la période choisie, les jours de phases affectées à chaque auditeur interne. La barre passe à l'orange puis au rouge à l'approche de la saturation : l'arbitrage d'une demande urgente se fait en quelques secondes.

- Période libre : une semaine, un mois, un trimestre.
- Le suivi des jours consommés par société de prestation est accessible depuis « Sociétés de prestation ».



# La liste des TI, filtrable et exportable

La liste donne la vue tabulaire du portefeuille : référence, nom, catégorie, étiquettes, priorité, statut, pilote, périodes prévue et réelle. Les champs personnalisés marqués « afficher dans la liste » apparaissent en colonnes — ici l'application concernée et l'entité commanditaire.

- Recherche sur le nom, la référence ou la description.
- Filtres par catégorie, étiquette, statut et priorité.
- Création unitaire d'un TI, ou reprise en masse par l'import.

Pilotage Audit

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Audits

Rechercher

Catégorie

Étiquette

Statut

Priorité

Import en masse

Nouvel audit

| Référence   | Nom                                      | Catégorie          | Étiquettes                                    | Priorité | Statut  | Pilote         | Période prévue          | Période réelle          | Application concernée | Entité commanditaire |
|-------------|------------------------------------------|--------------------|-----------------------------------------------|----------|---------|----------------|-------------------------|-------------------------|-----------------------|----------------------|
| TI-2025-026 | TI Revue de code API virements           | Revue de code      | DORA, PCI-DSS                                 | Moyenne  | Annulé  | Camille Durand | 2025-01-12 → 2025-01-21 | ? → ?                   | CODE-VIR              | Direction Paiements  |
| TI-2025-027 | TI Revue de code module authentification | Revue de code      | Nouveau service, DORA                         | Moyenne  | Terminé | Sofia Benali   | 2025-01-21 → 2025-02-01 | 2025-01-22 → 2025-02-01 | CODE-AUTH             | Direction Digitale   |
| TI-2025-028 | TI Revue de code moteur de scoring       | Revue de code      | Exposition Internet, Nouveau service, DORA    | Moyenne  | Terminé | Hugo Lefèvre   | 2025-02-01 → 2025-02-10 | 2025-02-01 → 2025-02-11 | CODE-SCOR             | Direction Crédits    |
| TI-2025-007 | TI Outil de gestion des crédits          | Applicatif interne | DORA, Plan de remédiation                     | Moyenne  | Terminé | Camille Durand | 2025-02-15 → 2025-02-24 | 2025-02-15 → 2025-03-01 | CREDIX                | Direction Crédits    |
| TI-2025-008 | TI Poste de travail conseiller           | Applicatif interne | Nouveau service, PCI-DSS, Plan de remédiation | Haute    | Terminé | Sofia Benali   | 2025-02-22 → 2025-03-07 | 2025-02-21 → 2025-03-06 | PDT-CONS              | Réseau d'agences     |
| TI-2025-009 | TI Référentiel client (CRM)              | Applicatif interne | Plan de remédiation, RGPD, Nouveau service    | Basse    | Terminé | Hugo Lefèvre   | 2025-03-09 → 2025-03-20 | 2025-03-12 → 2025-03-29 | CRM360                | Direction Données    |

Liste des audits avec champs personnalisés en colonnes.

Pilotage Audit — présentation de l'application

Captures réalisées sur un jeu de données fictif

page 6

# Tout un TI sur une page

La fiche rassemble l'identité du TI, sa programmation, ses phases, ses pré-requis et ses documents. Les **dates réelles**, saisies au fil de l'eau ou à la clôture, alimentent directement les statistiques de temps réels.

- Phases issues d'un template de la catégorie, puis ajustées ; chacune a son auditeur, ses dates prévues et réelles, et son indicateur de confirmation.
- Pré-requis auditeur cochés par le responsable de service, avec auteur et horodatage.
- Documents techniques et rapports attachés à l'audit, accessibles aux seuls utilisateurs authentifiés.

Fiche d'un TI terminé : phases réalisées, pré-requis validés, documents.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Retour aux audits

TI-2025-002

Critique

Terminé

TI Application mobile paiement

Campagne 2025 — Application mobile paiement. Périmètre validé avec l'entité commanditaire (Direction Digitale).

Statut

termine

Priorité

critique

Pilote d'audit

Inès Moreau

Société de prestation

SecuAudit

Contact responsable (nom)

Karim Haddad

Contact (email/tél.)

julien.marchand@banque-demo.fr

Responsable de service

Karim Haddad

Référence / identifiant TI

TI-2025-002

Catégorie

Applicatif externe

Début prévu

09/30/2025

Fin prévue

10/08/2025

Début réel

09/30/2025

Fin réelle

10/10/2025

Étiquettes

DORA RGPD Exposition Internet

Application concernée

MOBPAY

Entité commanditaire

Direction Digitale

Code de l'application dans le référentiel du SI

Référentiel de contrôle

NIST CSF

Budget engagé (k€)

11.2

Alimente les statistiques de temps réels

Pré-requis auditeur

Comptes de test nominatifs fournis

obligatoire

URL et périmètre technique validés

obligatoire

Autorisation d'audit signée

obligatoire

Contacts techniques et créneaux d'astreinte communiqués

obligatoire

Jeux de données de test disponibles

Filtrage WAF/IPS adapté pour la campagne

Nouveau pré-requis

Ajouter

Documents

Importer

Rapport\_final\_TI-2026.pdf

rapport

Perimetre\_technique.xlsx

technique

Phases

Appliquer un template Appliquer + Ajouter une phase

termine

Cadrage

Confirmé

termine

Début

09/30/

Fin

10/02/

Début réel

09/30/

Fin réelle

10/04/

Auditeur / pilote de phase

Inès Moreau

termine

Préparation & pré-requis

Confirmé

termine

Début

10/03/

Fin

10/06/

Début réel

10/05/

Fin réelle

10/10/

Auditeur / pilote de phase

Thomas Petit

termine

Exécution des tests

Confirmé

termine

Début

10/07/

Fin

10/15/

Début réel

10/11/

Fin réelle

10/21/

Auditeur / pilote de phase

Thomas Petit

termine

Restitution

Confirmé

termine

Début

10/16/

Fin

10/18/

Début réel

10/22/

Fin réelle

10/25/

Auditeur / pilote de phase

Léa Garnier

termine

Plan d'action

Confirmé

termine

Début

10/19/

Fin

10/22/

Début réel

10/26/

Fin réelle

10/31/

Auditeur / pilote de phase

Inès Moreau

Pilotage Audit — présentation de l'application

Captures réalisées sur un jeu de données fictif

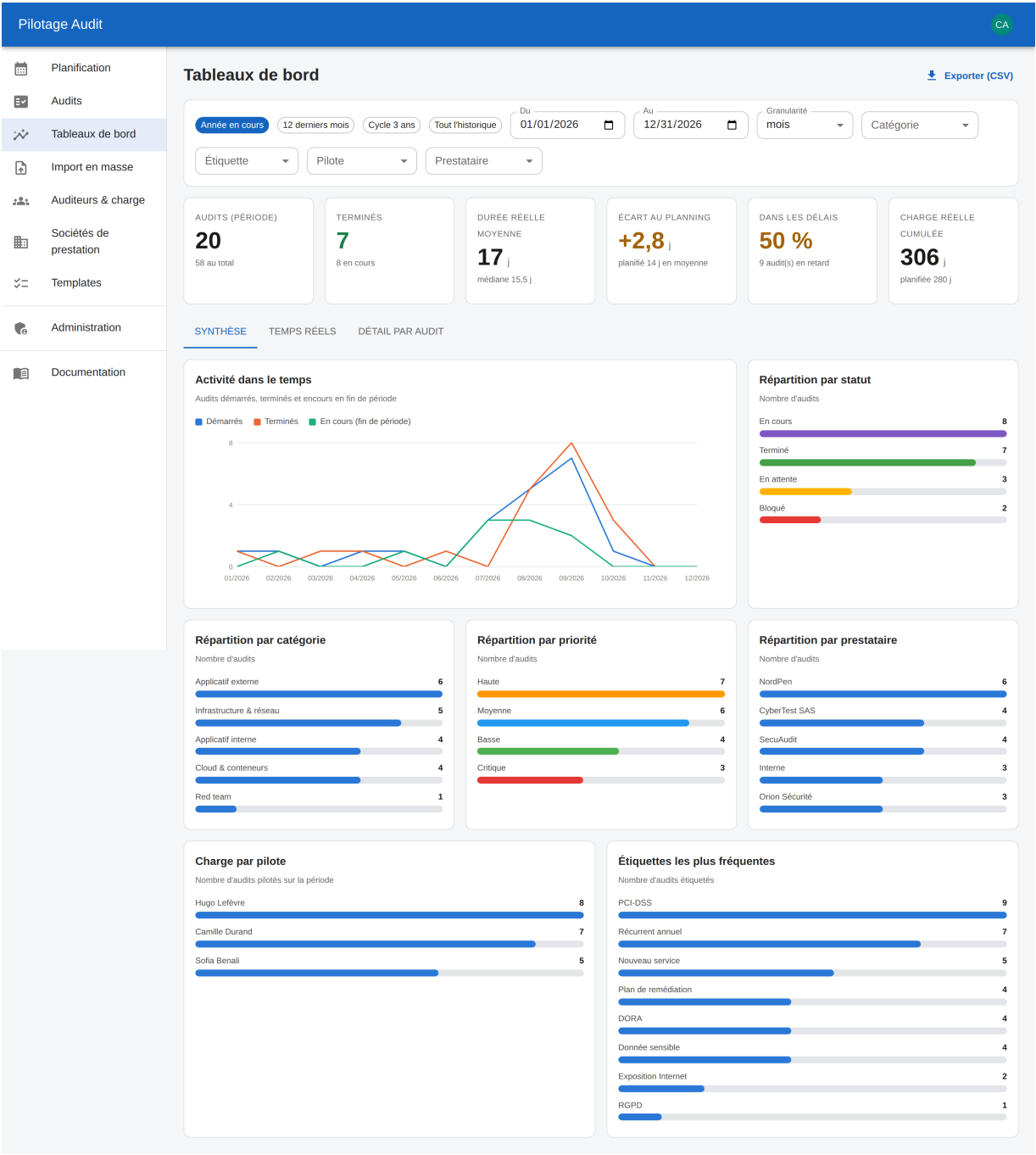
page 7

# Le tableau de bord de l'activité

Six indicateurs de tête résument la période : nombre de TI, terminés, durée réelle moyenne, écart au planning, respect des délais et charge cumulée. En dessous, l'activité dans le temps et les répartitions par statut, catégorie, priorité, prestataire, pilote et étiquette.

- Périodes prêtes à l'emploi : année en cours, 12 derniers mois, cycle de 3 ans, historique complet.
- Tous les graphiques portent la valeur en clair et sont repris en tableau : aucune lecture ne repose sur la seule couleur.
- Les mêmes filtres que le reste de l'application s'appliquent.

Tableaux de bord — synthèse de l'année en cours.

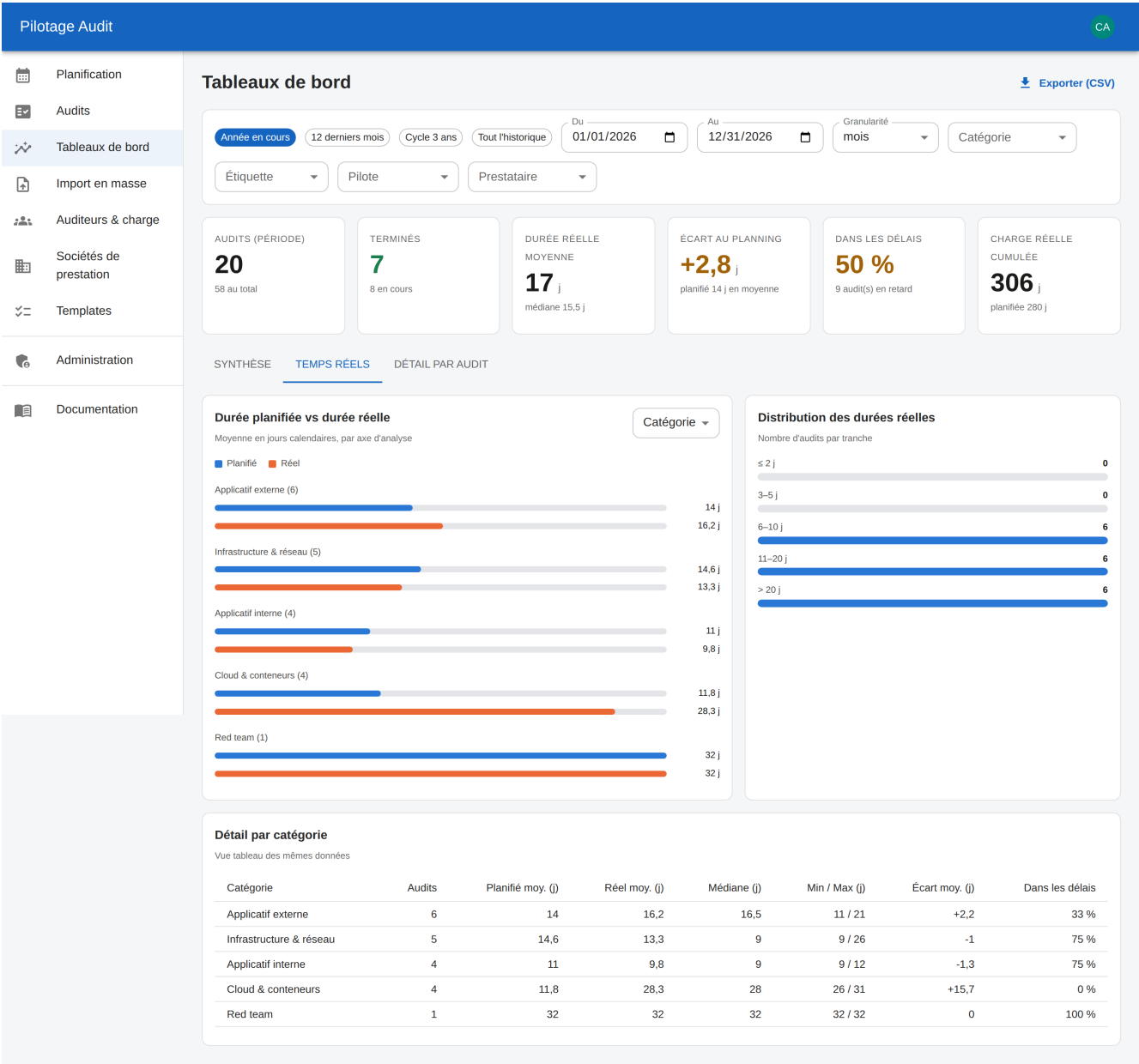


# Les temps réels, par axe d'analyse

L'onglet « Temps réels » compare, pour chaque axe (catégorie, priorité, prestataire, pilote ou type de phase), la **durée planifiée** et la **durée réellement constatée**. C'est la base des arbitrages de charge et de la renégociation des enveloppes prestataires.

- Moyenne, médiane, minimum, maximum, écart moyen et taux de respect des délais.
- Distribution des durées par tranche, pour repérer les campagnes atypiques.
- Onglet « Détail par audit » et export CSV pour une analyse hors outil.

Durée planifiée vs durée réelle, par catégorie.



# Importer le portefeuille depuis un fichier

L'import en masse reprend un fichier CSV ou Excel — typiquement le tableur de programmation existant. L'application lit le fichier, propose une correspondance pour chaque colonne et n'écrit rien en base avant la validation finale.

- Séparateur et encodage détectés automatiquement ; 5 000 lignes par lot.
- Les intitulés sont reconnus même s'ils diffèrent : « Criticité » devient la priorité, « Type d'audit » la catégorie.
- Les colonnes inconnues — ici « Application concernée », « Entité commanditaire », « Référentiel de contrôle » — peuvent être créées comme champs personnalisés.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Import en masse des TI

Modèle de fichier

Fichier

Colonnes

Détails manquants

Contrôle & import

4 ligne(s) lue(s) dans « demo-import.csv ». Vérifiez la correspondance des colonnes.

| Colonne du fichier                              | Exemples                              | Remplissage | Champ de l'application      | Champ personnalisé à créer                                                    |
|-------------------------------------------------|---------------------------------------|-------------|-----------------------------|-------------------------------------------------------------------------------|
| Code TI<br>type détecté : texte                 | TI-2027-101 - TI-2027-102 - TI-2...   | 100 %       | Référence / identifiant TI  | —                                                                             |
| Nom du test<br>type détecté : texte             | TI plateforme de signature élect...   | 75 %        | Nom de l'audit              | —                                                                             |
| Type d'audit<br>type détecté : texte            | Applicatif externe - Flux interban... | 100 %       | Catégorie                   | —                                                                             |
| Criticite<br>type détecté : liste               | haute - critique - moyenne - moy...   | 100 %       | Priorité                    | —                                                                             |
| Pilote<br>type détecté : texte                  | Camille Durand - Noémie Chast...      | 75 %        | Pilote d'audit              | —                                                                             |
| Prestataire<br>type détecté : texte             | SecuAudit - Trustwave Europe - ...    | 75 %        | Société de prestation       | —                                                                             |
| Date debut<br>type détecté : date               | 12/04/2027 - 03/05/2027 - 07/06/...   | 100 %       | Début prévu                 | —                                                                             |
| Date fin<br>type détecté : date                 | 23/04/2027 - 21/05/2027 - 11/06/...   | 100 %       | Fin prévue                  | —                                                                             |
| Etiquettes<br>type détecté : texte              | RGPD - DORA - Récurrent annuel        | 75 %        | Étiquettes (séparées par ;) | —                                                                             |
| Application concernee<br>type détecté : texte   | Exposition Internet - SWIFTGW ...     | 75 %        |                             | <div>Libellé<br/>Application concernee</div> <div>Type<br/>Texte c...</div>   |
| Entite commanditaire<br>type détecté : texte    | SIGNELEC - Direction Paiement...      | 75 %        |                             | <div>Libellé<br/>Entite commanditaire</div> <div>Type<br/>Texte c...</div>    |
| Referentiel de controle<br>type détecté : texte | Direction Juridique - PCI-DSS v4...   | 75 %        |                             | <div>Libellé<br/>Referentiel de controle</div> <div>Type<br/>Texte c...</div> |

Retour

Continuer

Étape 2 — correspondance des colonnes et création des champs manquants.

## Compléter ce qui n'existe pas encore en base

Les valeurs référencées par le fichier mais absentes de la base sont listées une à une : catégories, sociétés de prestation, pilotes, étiquettes. Pour chacune, l'analyste choisit de la **créer** en complétant ses informations, de la **rattacher** à un enregistrement existant, ou de l'**ignorer**.

- Le formulaire s'adapte à l'entité : jours alloués et contact pour une société, rôle et adresse pour un utilisateur.
- Un compte créé par import reste sans mot de passe tant qu'un administrateur ne l'a pas activé.
- Une proposition de rapprochement est faite quand un enregistrement proche existe déjà.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Import en masse des TI

Modèle de fichier

Fichier

Colonnes

Détails manquants

Contrôle & import

3 valeur(s) absente(s) de la base

Pour chacune, choisissez de la **créer** (en complétant les informations manquantes), de la **rattacher** à un enregistrement existant, ou de l'**ignorer** (le champ restera vide sur les audits concernés).

Catégorie

Flux interbancaires

1 ligne(s) concernée(s)

Action

Créer en base

Nom

Flux interbancaires

Code

Durée type (jours)

Description

Société de prestation

Trustwave Europe

1 ligne(s) concernée(s)

Action

Créer en base

Nom

Trustwave Europe

Contact (nom)

Contact (email)

Contact (téléphone)

Jours alloués

Utilisateur (pilote / responsable)

Noémie Chastain

1 ligne(s) concernée(s)

Action

Créer en base

Rôle

Pilote d'audit

Nom complet

Noémie Chastain

Email

Laissez vide : une adresse technique est générée, le compte reste sans mot de passe.

Retour

Continuer

Étape 3 — page de saisie des détails manquants.

# Contrôler avant d'importer

Dernière étape avant écriture : l'aperçu ligne à ligne signale les erreurs bloquantes, les avertissements et les doublons. Le comportement en cas de doublon se choisit, tout comme les valeurs par défaut et l'application automatique des templates de la catégorie.

- Une ligne sans nom d'audit est rejetée et le motif figure dans le rapport final.
- Un doublon est détecté sur la référence du TI, à défaut sur le nom.
- Chaque lot conserve son rapport ; les TI créés restent rattachés à leur import d'origine.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Import en masse des TI

Fichier

Colonnes

Détails manquants

Contrôle & import

Lignes lues

4

Lignes en erreur

1

Doublons détectés

0

Champs à créer

3

En cas de doublon

Statut par défaut

Priorité par défaut

Templates de la catégorie

Ignorer la ligne

planifie

moyenne

Appliquer pré-requis et phases

| # | État | Code TI     | Nom du test              | Type d'audit           | Criticité | Pilote          | Prestataire      | Date debut | Date fin   | Etiquettes       | Application concernée | Entité commanditaire | Referentiel de controle |
|---|------|-------------|--------------------------|------------------------|-----------|-----------------|------------------|------------|------------|------------------|-----------------------|----------------------|-------------------------|
| 1 | ✓    | TI-2027-101 | TI plateforme de sign... | Applicatif externe     | haute     | Camille Durand  | SecuAudit        | 12/04/2027 | 23/04/2027 | RGPD             | Exposition Internet   | SIGNELEC             | Direction Juridique     |
| 2 | ✓    | TI-2027-102 | TI passerelle SWIFT      | Flux interbancaires    | critique  | Noémie Chastain | Trustwave Europe | 03/05/2027 | 21/05/2027 | DORA             | SWIFTGW               | Direction Paiements  | PCI-DSS v4              |
| 3 | ✓    | TI-2027-103 | Audit configuration s... | Audit de configuration | moyenne   | Hugo Lefèvre    | CyberTest SAS    | 07/06/2027 | 11/06/2027 | Récurrent annuel | VEEAM                 | Production           | Guide ANSSI             |
| 4 | ⚠    | TI-2027-104 |                          | Applicatif interne     | moyenne   |                 |                  | 14/06/2027 | 18/06/2027 |                  |                       |                      |                         |

Retour

Importer 3 audit(s)

Étape 4 — contrôle des lignes, options et lancement de l'import.

# Le kanban se règle sans développement

Le panneau d'administration pilote intégralement le tableau : création, renommage, couleur, ordre, limite d'en-cours, statut appliqué, colonne par défaut ou finale, visibilité. Supprimer une colonne demande vers quelle autre déplacer ses audits — aucun TI n'est perdu.

- Une colonne peut n'appliquer aucun statut : elle sert alors d'étape purement organisationnelle.
- L'affichage des cartes se règle ici : champs visibles, couleur par priorité, statut ou catégorie, activation du glisser-déposer.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Administration

KANBAN

CATÉGORIES D'AUDIT

ÉTIQUETTES

CHAMPS PERSONNALISÉS

UTILISATEURS

Colonnes du tableau

+ Nouvelle colonne

| Ordre | Colonne                                                                          | Clé           | Statut appliqué | Limite d'en-cours | Audits | État       | Actions |
|-------|----------------------------------------------------------------------------------|---------------|-----------------|-------------------|--------|------------|---------|
| ↑ ↓   | Brouillon                                                                        | brouillon     | brouillon       | —                 | 3      | par défaut |         |
| ↑ ↓   | Planifié                                                                         | planifie      | planifie        | —                 | 7      |            |         |
| ↑ ↓   | En cours                                                                         | en_cours      | en_cours        | 6                 | 6      |            |         |
| ↑ ↓   | En attente                                                                       | en_attente    | en_attente      | —                 | 3      |            |         |
| ↑ ↓   | Revue qualité<br><small>Relecture du rapport avant restitution au métier</small> | revue_qualite | en_cours        | 3                 | 2      |            |         |
| ↑ ↓   | Bloqué                                                                           | bloque        | bloque          | —                 | 2      |            |         |
| ↑ ↓   | Terminé                                                                          | termine       | termine         | —                 | 33     | finale     |         |
| ↑ ↓   | Annulé                                                                           | annule        | annule          | —                 | 2      | finale     |         |

Affichage des cartes

Informations affichées sur les cartes

☒ Priorité

☒ Catégorie

☒ Étiquettes

☒ Pilote

☒ Prestataire

☒ Dates prévues

Couleur des cartes

Selon la priorité

☒ Glisser-déposer

☒ Afficher les colonnes vides

☒ Afficher les limites d'en-cours

Administration — colonnes du kanban et affichage des cartes.

Pilotage Audit — présentation de l'application

Captures réalisées sur un jeu de données fictif

page 13

# Catégoriser à trois niveaux

La **catégorie** classe le TI sur son axe principal et porte les templates de pré-requis et de phases. Les **étiquettes** ajoutent un classement transverse et multiple (DORA, PCI-DSS, exposition Internet...). Les **champs personnalisés** couvrent les données propres à l'organisation.

- Les trois niveaux servent de filtre dans les listes, le kanban, le planning et les tableaux de bord.
- Un champ peut être désactivé sans perdre les valeurs déjà saisies.
- Les champs créés par un import sont identifiés comme tels.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Administration

KANBAN

CATÉGORIES D'AUDIT

ÉTIQUETTES

CHAMPS PERSONNALISÉS

UTILISATEURS

La catégorie est l'axe principal de classement d'un audit (type de TI). Elle porte les templates de pré-requis et de phases, et sert de filtre dans le planning et les tableaux de bord.

Nom

Code

Couleur

Durée type (j)

Description

Ajouter

| Catégorie                 | Code    | Durée type | Description                                                   | Actions                 |
|---------------------------|---------|------------|---------------------------------------------------------------|-------------------------|
| ■ Applicatif externe      | APP-EXT | 10 j       | Applications exposées sur Internet (portails, API publiques)  | <div></div> <div></div> |
| ■ Applicatif interne      | APP-INT | 8 j        | Applications du système d'information interne                 | <div></div> <div></div> |
| ■ Infrastructure & réseau | INFRA   | 12 j       | Socle technique : réseau, AD, hyperviseurs, sauvegardes       | <div></div> <div></div> |
| ■ Cloud & conteneurs      | CLOUD   | 10 j       | Environnements cloud publics et plateformes conteneurisées    | <div></div> <div></div> |
| ■ Red team                | REDTEAM | 25 j       | Campagne offensive multi-vecteurs avec objectifs métier       | <div></div> <div></div> |
| ■ Audit de configuration  | CONFIG  | 5 j        | Revue de configuration par rapport aux guides de durcissement | <div></div> <div></div> |
| ■ Revue de code           | CODE    | 7 j        | Analyse de code source sur les composants sensibles           | <div></div> <div></div> |

# La documentation est dans l'outil

Une rubrique « Documentation » accompagne les utilisateurs directement dans l'application : prise en main, catégorisation, kanban, planning, import, tableaux de bord, exploitation. La documentation technique complète (architecture, modèle de données, API, exploitation, sécurité, dimensionnement) est versionnée avec le code.

- Recherche par mot-clé dans les rubriques.
- Référence interactive de l'API sur /api/docs pour les intégrations.

Documentation intégrée à l'application.

Pilotage Audit

CA

Planification

Audits

Tableaux de bord

Import en masse

Auditeurs & charge

Sociétés de prestation

Templates

Administration

Documentation

Documentation

Guide d'utilisation de l'application. La documentation technique complète (architecture, API, modèle de données, exploitation, dimensionnement) se trouve dans le dossier docs/ du dépôt, et la référence interactive de l'API sur [/api/docs](#).

Rechercher dans la documentation...

1. Prise en main

Rôles, premiers pas, organisation des menus.

L'application couvre le **pilotage** des audits / tests d'intrusion : planification, charge des auditeurs et prestataires, pré-requis, documents et suivi d'avancement. Elle ne stocke volontairement **ni les résultats d'audit ni les vulnérabilités**.

| Rôle                | Droits                                                                                                                              |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| admin               | Administration complète : utilisateurs, catégories, étiquettes, kanban, champs personnalisés, sociétés, templates, tous les audits. |
| pilote_audit        | Crée et modifie les audits, phases, pré-requis, documents ; réalise les imports en masse.                                           |
| responsable_service | Consulte les audits de son périmètre, coche les pré-requis, suit l'avancement.                                                      |

Parcours type d'un nouvel environnement

1. Créer les catégories d'audit et les étiquettes (Administration).

2. Adapter les colonnes du kanban au workflow de l'équipe.

3. Déclarer les sociétés de prestation et leurs jours alloués.

4. Créer les templates de pré-requis et de phases par catégorie.

5. Importer le portefeuille de TI existant (Import en masse).

6. Planifier : kanban, planning multi-échelles, plan de charge.

2. Catégoriser les audits

Catégorie principale, étiquettes transverses, champs personnalisés.

3. Kanban configurable

Colonnes, couleurs, limites d'en-cours, affichage des cartes.

4. Planning multi-échelles

Jour, semaine, mois, trimestre, année, cycle de 3 ans, vue glissante, sélection d'audits.

5. Import en masse des TI

Fichier, correspondance des colonnes, détails manquants, contrôle et import.

6. Tableaux de bord

Volumétrie, temps réels, écarts au planning, export CSV.

7. Exploitation & dimensionnement

Déploiement, sauvegardes, volumétrie supportée.

Pilotage Audit — présentation de l'application

Captures réalisées sur un jeu de données fictif

page 15

## Où en est le produit, et la suite

### État actuel

- L'ensemble des fonctions présentées est **opérationnel** et couvert par des tests automatisés.
- Le dimensionnement a été **mesuré**, pas estimé : base PostgreSQL peuplée de 5 000 audits et 25 000 phases, écrans du quotidien sous 250 ms, base d'environ 5 Ko par audit.
- La documentation fonctionnelle et technique est écrite et versionnée avec le code.

### Ce qu'il reste à décider avec l'équipe

- **Le workflow** : les colonnes du kanban livrées reprennent le cycle standard ; à ajuster à nos étapes réelles.
- **Les catégories et étiquettes** : à figer ensemble avant la reprise du portefeuille existant.
- **Les templates** de pré-requis et de phases par catégorie, qui conditionnent la qualité du planning.
- **La reprise de données** : quel tableur de référence importer en premier.
- **Le raccordement au SSO** de l'entreprise, prévu par le modèle mais non finalisé.

### Points de vigilance

|                             |                                                                                                                                                       |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Qualité des chiffres</b> | Les statistiques de temps réels ne valent que si les dates réelles sont saisies à la clôture. C'est le seul geste supplémentaire demandé aux pilotes. |
| <b>Comptes importés</b>     | Les utilisateurs créés par un import n'ont pas de mot de passe : un administrateur doit les activer et vérifier leur adresse.                         |
| <b>Avant production</b>     | Changer les secrets par défaut, placer l'application derrière TLS, mettre en place la sauvegarde de la base et du volume des documents.               |

*Les données visibles dans ce document (noms d'audits, de pilotes, de prestataires et de systèmes) sont **entièrement fictives** et ne décrivent aucun périmètre réel.*